

RCI Cybersecurity Analysis Report

0x2A Security

ANALYST: S M Mohiuddin Mahmood

DATE: Mar. 19. 2025

Executive Summary

What happened with Rigel Cybernetics Institute is unfortunate. This unfortunate circumstance happened because of pre-cautions that were not taken in time and a lack of resources at the time. Below, I will write out 3 of the most important recommendations that will help RCI get back on its feet and suppress any other unforeseen future circumstances.

RCI should set up a dedicated SOC team that focuses on continuously monitoring our systems and updating SIEM. Without one, we remain vulnerable to attacks like ransomware, which previously resulted in lost patient records. A proactive SOC team would help safeguard our data and ensure that our commitment to impeccable customer privacy is maintained.

Making cybersecurity training mandatory for all new employees is also crucial. By including this training in the onboarding process, staff will be better equipped to recognize phishing emails and scams. This step is essential, as previous breaches due to untrained staff have compromised patient care by losing vital records, which directly impacts our service quality.

Finally, establishing an Incident Response Team (IRT) and regularly updating our Incident Response Plan (IRP) is a must. The current plan, being two years old, may not address today's threats adequately. A dedicated IRT can quickly act to restore systems and secure data if an incident occurs, aligning with our priority of innovative software development for exceptional patient care.

Recommendations

RECOMMENDATION 1: Organizing the SOC team

SOC teams should be part of the organization that will be updating SIEMS and implementing continuous monitoring. implementing a SOC team would make sure to prioritize SIEM. No SOC teams in place. Every organization needs SIEM. Missing this part from an organization can impact drastic challenges and even risky situations. RCI has fallen victim to ransomware, resulting in the loss of important patient records for which they had no backup. If there was a SOC team in place who were monitoring continuously, this wouldn't have happened as their main job is to be cautious of any virus or hacker hacking into the system. One of the key priorities of RCI is "impeccable protection of customer privacy". The solution to this specific problem will do exactly that. When there is a SOC in place in the company, there is continuous monitoring and a security system who are there to pick up when things go left.

RECOMMENDATION 2: Make Cybersecurity training an obligation during the onboarding process of employees.

Create policies requiring employees to finish CyberSecurity awareness training as part of the onboarding process. This will prepare the employees by giving them an understanding on how to spot phishing emails and external scam links. No policies require employees to undergo cybersecurity awareness training. This means employees aren't trained on when to spot phishing emails or possible scams. RCI has lost all of its last 8 months of important patient records because of opening a phishing email. This clearly demonstrated that the employee had no idea whether the email was real or fake. If all of the employees of RCI had gotten through a cybersecurity awareness training then this wouldn't have happened. Another one of the key priorities of RCI is "exceptional patient care". When the attacker attacked the patient data server comprising the important patient records, it resulted in not being able to care for patients since they lost all the information about their patients. Since now the information is not available, services cannot be provided to the patients. So to provide, exceptional patient care, we have to make sure everything else is on point and secured, whether that is through cybersecurity awareness or exceptional physical service.

RECOMMENDATION 3: Having an IRT/IRP

An Incident Response Team should be hired to create/plan/implement/process an incident response plan. If things fall out of plan and the system gets compromised, there needs to be a backup solution. In this case, it is the IRT. IRT creates, plans, and Implements incident response plans. By having an IRT in the organization, they can always rely on them to fully back up if anything goes wrong. The IRP was updated 2 years ago. Time changes as well as circumstances. An Incident Response Plan which was created 2 years ago for that specific time frame, will not work today. IRP needs to be updated every now and then based on changes in the system or updates to the system. If there was an IRT in place on RCI, then there would be a recently updated IRP that could recover the data that was stolen by the attacker. No services would need to be stopped and no server would be compromised for a long period of time. Lastly, the other one of the key priorities of RCI is - "innovative software development for delivering that exceptional patient care". Not having an Incident Response Plan sounds like something that goes directly against the priority listed. Having an innovative software development doesn't just mean the "software" It's also anything and everything that is related to software and has importance in the system. Having an outdated IRP is no benefit because the situation changes and while 2 years may not sound like a long time, it is when it comes to company infrastructure and software. So having everything up to date is a necessary move.

RECOMMENDATION 4: training employees on Cybersecurity awareness.

Implement Cyber Security Awareness training every 6 months or when systems are updated. Just implementing this simple step, will bring down further cases like the one that happened recently. The employee opened a phishing email that looked like a patient's record but was filled with ransomware. If she had any training on how to spot phishing emails or scam links, this casualty wouldn't have happened. By implementing this simple solution, RCI could have saved tons of money. Currently, RCI is spending money on ransomware to get its patient records back. If the employee who opened the phishing email was properly trained in cybersecurity awareness. No phishing attempt would have been successful. This solution is also relevant to "exceptional patient care". Since the data were lost during the phishing attack, all services needed to be stopped due to the lack of information about the patients. If this wouldn't have happened RCI would smoothly operate just as it did until recently.